Sécurité des Systèmes et Réseaux

VPN SSL et Supervision (Logs)

Séance 6 : Accès Distants et Forensics

Crée par RACHID BOUSELAMA

Scénario : Le Télétravail d'Urgence

La direction de Nexus-Industry impose le télétravail pour l'équipe de développement. Mission : Configurer un portail VPN SSL sécurisé permettant aux employés externes d'accéder aux ressources internes (Serveur Web en DMZ) depuis Internet, tout en traçant chaque connexion.

Table des Matières

(Clic droit sur la table des matières > Mettre à jour le champ pour actualiser les numéros de page)

Partie I : Théorie - VPN et Traçabilité.....3

1. Les Réseaux Privés Virtuels (VPN) 3

1.1 IPsec vs SSL VPN 3

2. Authentification et MFA 4

3. Supervision et Logs (Forensics).....4

Partie II : Fiche Labo - Déploiement VPN SSL 5

4. Prérequis.....5

5. Étape 1 : Création des Utilisateurs et Groupes.....5

6. Étape 2 : Configuration du Portail VPN.....6

7. Étape 3 : Configuration Générale VPN.....7

8. Étape 4 : La Politique de Firewall.....8

9. Étape 5 : Test de Connexion.....9

10. Étape 6 : Analyse Forensics.....10

11. Livrable 11

Partie I : Théorie - VPN et Traçabilité

Cette première partie présente les concepts fondamentaux des réseaux privés virtuels (VPN), des mécanismes d'authentification multi-facteurs (MFA), ainsi que les principes de supervision et de traçabilité des connexions. Ces notions sont essentielles pour comprendre et sécuriser les accès distants dans un environnement professionnel.

1. Les Réseaux Privés Virtuels (VPN)

Un VPN (Virtual Private Network) est une technologie qui permet de créer un**tunnel chiffré**au-dessus d'un réseau public comme Internet. Cette technologie offre plusieurs avantages fondamentaux :

- **Confidentialité :**Les données sont chiffrées, empêchant toute interception par des tiers
- **Intégrité :**Les données ne peuvent pas être modifiées en transit
- **Authentification :**Seuls les utilisateurs autorisés peuvent accéder au réseau
- **Anonymat :**L'adresse IP réelle de l'utilisateur est masquée

Dans le contexte du télétravail, le VPN permet aux employés de se connecter de manière sécurisée aux ressources internes de l'entreprise depuis n'importe où dans le monde, comme s'ils étaient physiquement présents sur le site.

1.1 IPsec vs SSL VPN

Il existe deux grandes familles de VPN, chacune adaptée à des cas d'usage différents :

Caractéristique	IPsec (Site-to-Site)	SSL VPN (Client-to-Site)
Usage	Relier deux bâtiments	Télétravailleurs nomades
Niveau OSI	Couche 3 (Réseau)	Couche 7 (Application)
Transparence	Permanent, transparent	À la demande
Client	Intégré au routeur	Navigateur ou FortiClient

Mode Web (Portal) :L'utilisateur accède aux ressources via un navigateur web sans nécessiter l'installation d'un client VPN. Ce mode est limité aux services Web, FTP et RDP, mais offre une grande simplicité de déploiement.

Mode Tunnel :Nécessite l'installation d'un client VPN (comme FortiClient). L'utilisateur reçoit une adresse IP virtuelle faisant partie du réseau interne, permettant un accès complet à toutes les ressources.

2. Authentification et MFA

L'authentification par mot de passe seul n'est plus suffisante pour sécuriser les accès distants. Les organismes de référence en cybersécurité (ANSSI, NIST) recommandent fortement l'utilisation de l'**authentification multi-facteurs (MFA)**pour tous les accès VPN.

Les trois facteurs d'authentification :

0. **Ce que je sais**: Mot de passe, code PIN, réponse à une question secrète
1. **Ce que je possède**: Token physique (FortiToken), smartphone (OTP), carte à puce
2. **Ce que je suis**: Empreinte digitale, reconnaissance faciale, iris

Le MFA combine au moins deux de ces facteurs. Par exemple, un utilisateur doit saisir son mot de passe (facteur 1) puis valider une notification sur son smartphone (facteur 2). Même si le mot de passe est compromis, l'attaquant ne peut pas accéder sans le second facteur.

3. Supervision et Logs (Forensics)

La supervision et la journalisation (*logging*) sont des éléments cruciaux de la sécurité. En cas d'incident de sécurité, les logs constituent la**seule preuve juridique**pouvant être utilisée pour l'analyse forensique et les procédures judiciaires.

Les trois types de logs essentiels :

Traffic Logs : Enregistrent les flux réseau (qui communique avec qui). Informations clés : adresse IP source, adresse IP destination, port, protocole, volume de données.

Event Logs :Événements système comme les connexions administrateur réussies ou échouées, les montées et descentes de tunnel VPN, les alertes de charge CPU.

Security Logs :Détections des modules de sécurité UTM : virus bloqués, attaques IPS détectées, tentatives d'intrusion.

Une bonne pratique consiste à centraliser tous ces logs sur un serveur SIEM (Security Information and Event Management) pour une analyse corrélée et une détection plus rapide des menaces.

Partie II : Fiche Labo - Déploiement VPN SSL

Cette partie présente les étapes détaillées pour configurer un portail VPN SSL sur un FortiGate. Suivez chaque étape attentivement et insérez vos captures d'écran dans les espaces prévus.

4. Prérequis

Avant de commencer, assurez-vous d'avoir :

- Un FortiGate VM fonctionnel avec accès Internet (Port 1)
- Une machine hôte physique (votre PC) qui simulera l'utilisateur sur Internet
- Une VM Metasploitable accessible en DMZ (IP : 172.16.1.10)

5. Étape 1 : Création des Utilisateurs et Groupes

Nous allons créer un compte local pour le télétravailleur.

1.Allez dans**User & Device > User Definition > Create New**

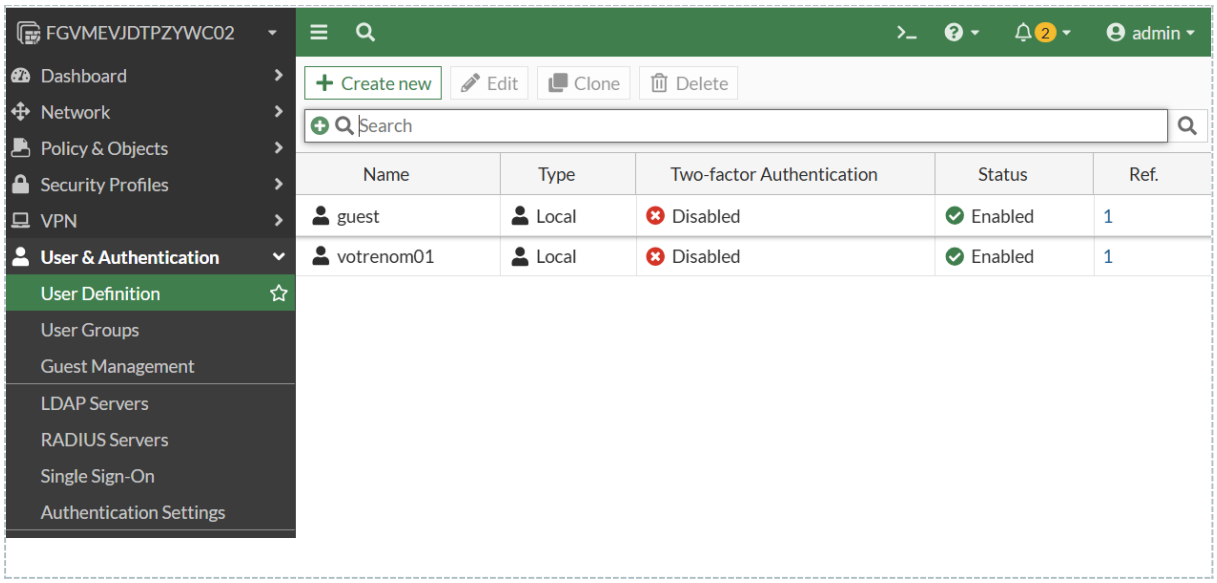
2.Type :**Local User**

3.Username :**votrenom01**/ Password :**Fortinet123!**

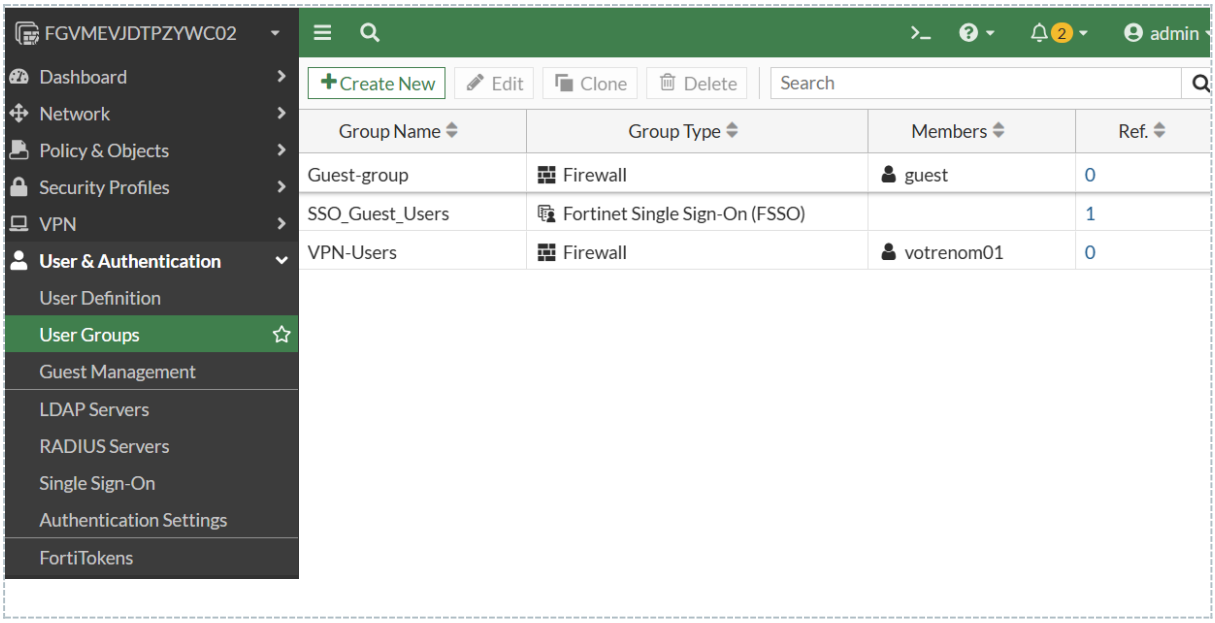
4.Email :**(Facultatif)**- Validez

5.Allez dans**User & Device > User Groups > Create New**

6.Nom :**VPN-Users**- Ajoutez votrenom01 dedans



Capture d'écran : Création de l'utilisateur votrenom01



Capture d'écran : Création du groupe VPN-Users

6. Étape 2 : Configuration du Portail VPN (Web Mode)

Nous allons définir ce que l'utilisateur voit quand il se connecte.

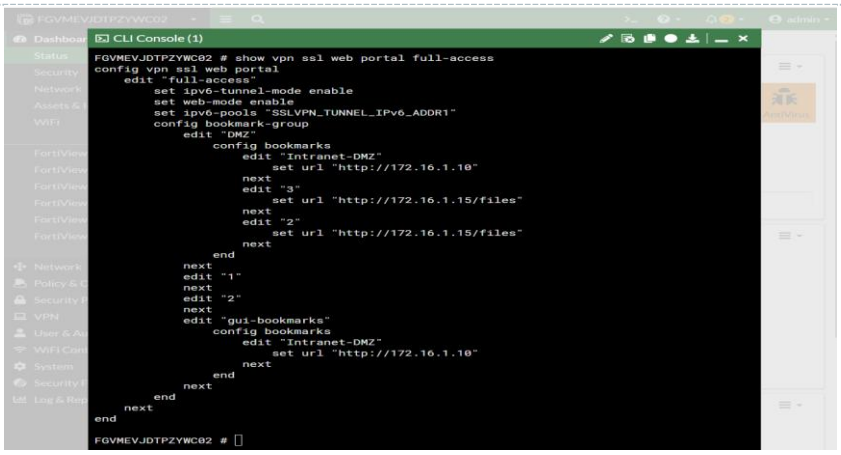
1.Allez dans**VPN > SSL-VPN Portals**

2.Éditez le portail**web-access**

3.Predefined Bookmarks : Cliquez sur**"Create New"**

Nom	Intranet-DMZ
Type	HTTP/HTTPS
URL	http://172.16.1.10 (IP de Metasploitable/DMZ)

4.Validez



Capture d'écran : Configuration du portail web-access avec le bookmark Intranet-DMZ

7. Étape 3 : Configuration Générale VPN (Settings)

Nous allons activer l'écoute du VPN sur l'interface publique.

1.Allez dans**VPN > SSL-VPN Settings**

2.Listen on Interface(s) : Sélectionnez**port1 (WAN)**

3.Listen on Port : Changez**443**en**10443**(pour éviter le conflit avec l'administration HTTPS)

4.Authentication/Portal Mapping : Cliquez sur**"Create New"**

User/Group	VPN-Users
Portal	web-access

5.Validez (**Apply**)

```
FGVMEVJDTPZYWC02 # show vpn ssl settings
config vpn ssl settings
    set servercert "Fortinet_Factory"
    set source-interface "port1"
    set source-address "all"
    set default-portal "full-access"
    config authentication-rule
        edit 1
            set groups "VPN-Users"
            set portal "full-access"
        next
    end
end

FGVMEVJDTPZYWC02 #
```

Capture d'écran : Configuration SSL-VPN Settings avec le port 10443

8. Étape 4 : La Politique de Firewall (Crucial)

Sans règle, le trafic ne passe pas de l'interface virtuelle VPN vers le réseau interne.

1.Allez dans**Policy & Objects > Firewall Policy > Create New**

Name	VPN-to-DMZ
Incoming Interface	SSL-VPN Tunnel Interface (ssl.root)
Outgoing Interface	Port 3 (DMZ)
Source	all ET VPN-Users (sélectionnez le groupe !)

Destination	Srv-Metasploitable (ou le sous-réseau DMZ)
Service	HTTP, HTTPS, PING
Action	ACCEPT
NAT	Disabled

Note sur le NAT :Généralement pas nécessaire en mode Web, mais Enabled en mode Tunnel. Laissez Disabled pour ce test Web.

```
FGVMEVJDTPZYWC02 # show firewall policy 4
config firewall policy
    edit 4
        set name "VPN-to-DMZ"
        set uuid 77b476a4-308b-51f1-630c-eaa0cfaf82d4
        set srcintf "ssl.root"
        set dstintf "port3"
        set action accept
        set srcaddr "all"
        set dstaddr "Srv-Metasploitable"
        set schedule "always"
        set service "HTTP" "HTTPS" "PING"
        set groups "VPN-Users"
    next
end
```

Capture d'écran : Politique de firewall VPN-to-DMZ

9. Étape 5 : Test de Connexion (Depuis l'extérieur)

Simulation sur votre ordinateur physique (Windows/Mac) :

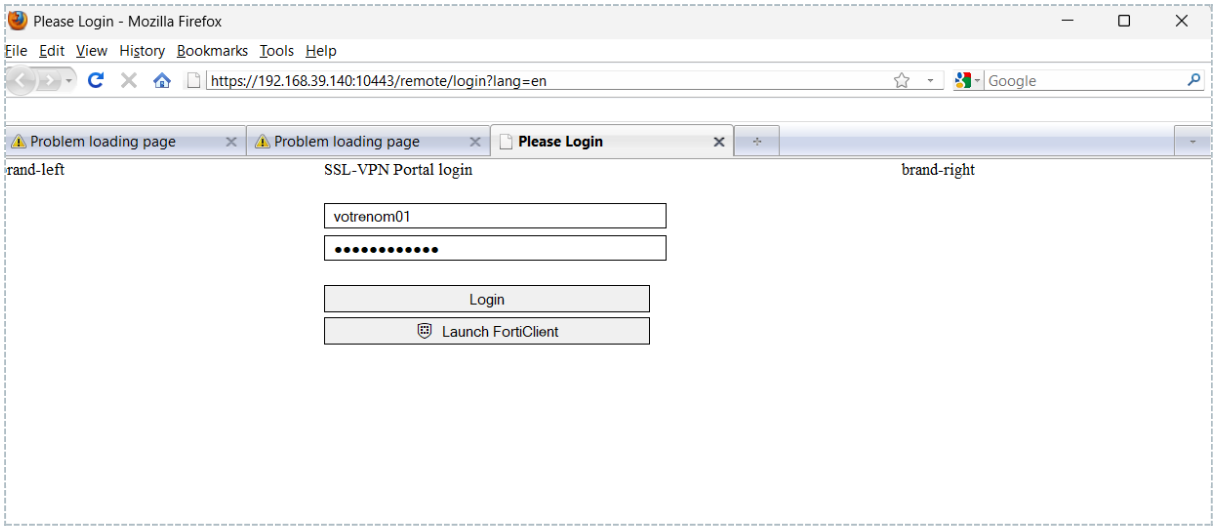
1.Ouvrez votre navigateur et tapez l'URL :**https://[IP_WAN_FORTIGATE]:10443**

2.Acceptez**l'avertissement de certificat**(Self-signed)

3.Loguez-vous avec**votrenom01**/**Fortinet123!**

4.Vous arrivez sur**le portail**- Cliquez sur le signet Intranet-DMZ

5.Succès :**Vous accédez au site web de la VM Metasploitable à travers le tunnel VPN !**



Capture d'écran : Page de connexion VPN SSL (https://IP:10443)

10. Étape 6 : Analyse Forensics (Supervision)

Un incident a eu lieu. Vous devez prouver qui s'est connecté.

1.Retournez sur**l'interface admin du FortiGate**

2.Allez dans**Log & Report > System Events > VPN Events**

3.Trouvez la ligne indiquant**"SSL VPN login success"**

Notez les informations suivantes :

- **L'heure de connexion :**_____
- **L'adresse IP publique source (celle de votre PC physique) :**_____
- **Le nom de l'utilisateur :**_____

4.Allez dans**Dashboard > FortiView VPN**pour voir les tunnels actifs en temps réel

```
FGVMEVJDTPZYWC02 # execute log display
928 logs found.
10 logs returned.

1: date=2026-04-05 time=09:09:54 eventtime=1775405394390517063 tz="-0700" logid="010003
2001" type="event" subtype="system" level="information" vd="root" logdesc="Admin login
successful" sn="1775405394" user="admin" ui="jsconsole" method="jsconsole" srcip=10.0.0
.33 dstip=10.0.0.1 action="login" status="success" reason="none" profile="super_admin"
msg="Administrator admin logged in successfully from jsconsole"

2: date=2026-04-05 time=09:09:45 eventtime=1775405385607590765 tz="-0700" logid="010003
2001" type="event" subtype="system" level="information" vd="root" logdesc="Admin login
successful" sn="1775405385" user="admin" ui="https(10.0.0.33)" method="https" srcip=10.
0.0.33 dstip=10.0.0.1 action="login" status="success" reason="none" profile="super_admi
n" msg="Administrator admin logged in successfully from https(10.0.0.33)"
```

Capture d'écran : Logs VPN montrant la connexion de votrenom01